Анализ ELK и Wazuh для сбора и хранения событий ИБ от ИИ-инструментов

Статус документа: Технический анализ для ИБ-подразделения
Условия контура: 100% On-Premise / Только бесплатные версии

1. Цель и исходные условия

До конца 4 квартала необходимо определить open-source платформу для централизованного сбора, долгосрочного хранения, сквозного поиска и анализа событий информационной безопасности, формируемых ИИ-инструментами ИТ-подразделений.

Исходные параметры контура:

- Развертывание осуществляется строго в закрытом локальном периметре (On-Premise) без использования внешних облачных сервисов и публичных S3-хранилищ.
- Рассматриваются исключительно бесплатные версии систем: Wazuh 4.14.8 и ELK Stack 9.5.5 (лицензия Basic).
- К целевым событиям относятся: запросы пользователей (prompt), ответы моделей (response), вердикты систем защиты (guardrails), технические метаданные (идентификаторы сессий session_id, метки времени, ID пользователей).
- Сбор полных текстов промптов и ответов обязателен для проведения ретроспективных ИБ-расследований, что требует реализации механизмов маскирования чувствительных данных на лету.

2. Критерии оценки

Оценка систем проводится по жестким условиям допуска. Если система не проходит критическое требование, она не может быть выбрана в качестве целевого основного хранилища.

- Сбор и доставка: Поддержка больших сообщений (мегабайтные текстовые промпты), прямой прием по HTTP REST API от локальных микросервисов ИИ, устойчивость к пиковым нагрузкам.
- Локальное хранение и архив: Автоматическое управление жизненным циклом данных (ротация, очистка дисков), возможность сквозного поиска по историческим логам без ручной распаковки файлов.
- Маскирование на лету: Способность находить регулярными выражениями и заменять маской ПДн, пароли и коммерческую тайну до записи события на диск.
- Трудозатраты инженеров: Объем дефицитного времени специалистов, расходуемый на поддержку и адаптацию системы под изменения форматов логов ИИ.

3. Сравнительный анализ: механизмы работы и критические проблемы

3.1. Обработка больших текстовых сообщений (Промпты и Ответы)

ELK Stack 9.5.5: По умолчанию лимит на размер одного входящего JSON-документа в Elasticsearch составляет 100 МБ. Буфер Logstash ограничивается только выделенной ему RAM. Система без задержек принимает длинные контексты ИИ, программный код и анализируемые документы.

Wazuh 4.14.8: На уровне исходного кода ядра Wazuh (компонент analysisd) установлен жесткий архитектурный лимит размера строки события — 64 КБ.

Критическая проблема: При отправке длинного промпта или развернутого ответа модели ядро Wazuh безвозвратно обрежет лог. Это приведет к нарушению структуры JSON, невозможности парсинга декодерами и полной потере ИБ-контекста.

3.2. Сбор полного потока данных (Легитимный трафик vs Алерты)

ELK Stack 9.5.5: Стек изначально спроектирован как высокомасштабируемая база данных. Схема работы строится по принципу «пишем 100% входящего трафика, нормализуем и осуществляем поиск по всему массиву».

Wazuh 4.14.8: Архитектурно Wazuh заточен под фиксацию алертов (аномалий). Весь поток сырых легитимных логов по умолчанию сбрасывается в плоский файл archives.json.

Критическая проблема: Если принудительно включить полную индексацию всех архивов в базу данных Wazuh Indexer, локальный сервер Wazuh Manager столкнется со сверхвысокой нагрузкой на CPU/RAM из-за постоянной сверки огромных объемов легитимного текста со всем набором правил SIEM.

3.3. Локальное архивное хранение и сквозной поиск

ELK Stack 9.5.5: Управление жизненным циклом логов реализуется через локальные политики ILM (Index Lifecycle Management). Данные автоматически и прозрачно перемещаются между локальными дисками разного типа по цепочке Hot → Warm → Cold.

Wazuh 4.14.8: Ротация логов выполняется утилитой wazuh-monitord, которая сжимает старые файлы в локальные архивы .json.gz.

Критическая проблема: Поиск по сжатым архивам Wazuh через дашборд невозможен. При необходимости расследовать инцидент трехмесячной давности инженеру ИБ придется вручную скачивать архивные файлы с дисков серверов и искать данные утилитой grep.

3.4. Маскирование конфиденциальных данных на лету

ELK Stack 9.5.5: Встроенные механизмы Logstash (плагин mutate с функцией gsub) или Elasticsearch Ingest Pipelines (процессор Redact) перехватывают поле prompt и по регулярным выражениям вырезают секреты до фиксации лога на накопителе.

Wazuh 4.14.8: Штатные средства очистки текста в процессе приема лога практически отсутствуют.

Критическая проблема: Для исключения попадания ПДн и коммерческой тайны в базу ИБ-департаменту придется развертывать стороннее прокси-решение перед Wazuh для предварительного парсинга и очистки трафика, что усложняет локальную архитектуру.

3.5. Каналы приема данных и API

ELK Stack 9.5.5: Elasticsearch предоставляет стандартный HTTP REST API. Любой внутренний ИИ-сервис или локальный валидатор (например, Llama Guard) может напрямую отправлять события методом POST.

Wazuh 4.14.8: API управления Wazuh не предназначено для массового приема сторонних логов.

Критическая проблема: Чтобы доставить логи в Wazuh, локальные ИИ-сервисы необходимо обязать писать данные в локальный Syslog или текстовые файлы на диске, которые затем будут вычитываться агентом Wazuh, создавая лишние дисковые операции I/O.

3.6. Анализ распределения трудозатрат инженеров

При выборе ELK Stack: Основное время инженера уходит на проектирование и администрирование баз данных. Специалист будет настраивать схемы данных (Mapping Templates) для предотвращения переполнения памяти, оптимизировать индексы под терабайтные текстовые массивы и настраивать правила очистки дисков (ILM).

При выборе Wazuh: Основное время инженера превратится в «ад регулярных выражений» (PCRE). Из-за жестких требований Wazuh к структурированию данных, ИБ-специалисту придется вручную писать и постоянно переписывать сложные XML-декодеры под каждое изменение формата JSON. Любая новая запятая в структуре лога ИИ потребует переписывания декодеров Wazuh, что приведет к операционному тупику.

4. Сводная таблица сравнения (Локальный контур, Бесплатные версии)

Критерий оценки	Wazuh 4.14.8 (Бесплатный)	ELK Stack 9.5.5 (Basic)	Решение для ИИ-задачи
Макс. размер лога	Жесткий лимит 64 КБ на событие. Длинные промпты будут обрезаны.	Лимит 100 МБ на документ по умолчанию. Вмещает любые контексты.	ELK Stack. Wazuh сломает структуру больших логов.
Сбор легитимного потока	Оптимизирован под алерты. Сбор всего трафика перегрузит менеджер.	Спроектирован под полный сбор и поиск по терабайтам сырых данных.	ELK Stack. Идеален для ретроспективного анализа.
Поиск по архивам	Невозможен через дашборд. Архивы лежат в плоских файлах .gz.	Встроенные локальные политики ILM. Автоперенос данных на дешевые диски.	ELK Stack. Позволяет управлять жизненным циклом данных.
Маскирование лету	Сложно. Требует написания внешних скриптов-прослоек.	Из коробки. Процессор Redact или плагин gsub в Logstash.	ELK Stack. Позволяет соблюдать требования ИБ штатно.
Прием логов по API	Отсутствует открытый REST API для массового приема логов.	Прямой стандартный HTTP REST API для JSON-потоков.	ELK Stack. Напрямую интегрируется с микросервисами ИИ.
Трудозатраты инженера	Написание регулярных выражений. Бесконечная правка XML-декодеров.	Проектирование БД. Настройка индексов, маппингов и чистка дисков.	ELK Stack. Тратить время на администрирование БД эффективнее.

5. Влияние ограничений бесплатной версии ELK Basic и возможности Премиума

Так как рассматривается только бесплатная версия ELK Stack (Basic) в закрытом контуре, необходимо учитывать ее лимиты и понимать преимущества платной лицензии для будущей оптимизации.

Ограничения бесплатной версии ELK Basic в локальном периметре:

1. Отсутствие разделения доступа внутри индекса: Нельзя скрыть текстовое поле prompt от дежурных аналитиков SOC, оставив его видимым только для ИБ-офицеров. Доступ дается на весь индекс целиком. Обходной путь: Инженерам придется разделять поток в Logstash на два разных индекса: ai-logs-public (без промптов) и ai-logs-restricted (полный текст).

2. Отсутствие нативного алертинга: Модуль Watcher заблокирован. Обходной путь: Требуется установка и поддержка локального Python-сервиса ElastAlert2.

Что дает коммерческая Premium-подписка ELK для оптимизации процессов ИБ:

- Field-level security: Гибкое скрытие или открытие конкретных строк и полей разным группам локальных пользователей в рамках одной базы данных и одной панели Kibana.
- Searchable Snapshots (Поиск по снимкам): Перенос архивных индексов на дешевые локальные дисковые массивы или локальные хранилища типа MinIO в виде сжатых снимков с сохранением возможности искать по ним через Kibana без процедуры восстановления. Экономит до 70-80% серверных мощностей.
- Встроенный локальный Machine Learning: Автоматическое выявление аномалий в промптах пользователей (например, выявление попыток массовой выгрузки конфиденциального исходного кода через ИИ-помощников в нерабочее время).

6. Предлагаемый план PoC (Программы испытаний)

Для практического подтверждения результатов анализа до конца 4 квартала утверждается следующий детальный план тестирования на стендах:

1. Этап согласования параметров: Зафиксировать перечень тестовых ИИ-источников, форматы передачи JSON, средний/пиковый EPS, а также определить размеры «длинных» промптов (от 100 КБ до 5 МБ).
2. Проверка каналов приема: Подключить локальные ИИ-источники к обеим системам. Проверить доступность прямой отправки по API в ELK и стабильность фиксации событий через локальные файлы/Syslog в Wazuh.
3. Стресс-тест на лимиты сообщений (Критический этап): Направить в обе системы промпты размером 128 КБ, 1 МБ и 5 МБ. Зафиксировать факт и объем обрезания данных в Wazuh и корректность индексации в ELK. Проверить устойчивость систем при отправке некорректного (невалидного) JSON.
4. Тестирование аналитики и ИБ-функционала: Проверить удобство группировки событий по session_id в Kibana Lens для выстраивания хронологического таймлайна диалога с ИИ. Оценить работу процессора Redact по маскированию тестовых номеров кредитных карт и паролей в теле промпта.
5. Нагрузочные замеры: Измерить задержку индексации при пиковом EPS, процент потери событий при искусственном сбое сети, скорость заполнения локальных дисков и время, необходимое на поиск данных в локальном архиве за прошлый период.

7. Предварительный вывод и рекомендация

Для централизованного сбора, маскирования и долгосрочного хранения полного потока разнородных ИИ-событий (включая полнотекстовый анализ prompt/response) бесплатная платформа Wazuh 4.14.8 аппаратно неприменима в качестве основного хранилища из-за жесткого лимита в 64 КБ на лог и отсутствия механизмов сквозного поиска по архивам.

Рекомендуется утвердить развертывание бесплатного локального кластера ELK Stack 9.5.5 (или полностью открытого аналога OpenSearch для обхода ограничений прав доступа).

Весь тяжелый поток текстовых промптов, ответов и метаданных от ИИ и локальных валидаторов (Llama Guard) необходимо направлять напрямую в него. В Logstash реализовать маскирование ПДн и ротацию индексов по локальным дискам.

8. Вопросы, требующие подтверждения

1. Возможность использования бесплатного форка OpenSearch вместо оригинального Elastic Stack Basic для получения бесплатного функционала разграничения прав доступа на уровне полей лога (Field-level security).
2. Окончательный перечень локально развернутых ИИ-продуктов и готовность их команд разработки передавать логи в формате JSON по HTTP REST API.
3. Точные объемы выделяемых локальных дисковых массивов (HDD/SSD) в периметре под хранение тяжелых текстовых данных ИИ-сессий на период опытной эксплуатации.